K.MOUNITH
192425090
B.TECH-AIML

SLOT -D:CSA6305 - THREAT INTELLIGENCE AND NETWORK SECURITY

Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

ANSWERS

1. Malware is malicious software designed to harm a computer, disrupt its operation, steal information, or gain unauthorised access.

A virus attaches itself to a legitimate file or program. It spreads when an infected file is shared or opened, and it can corrupt or delete files.

A worm copies itself and spreads across networks without attaching to another file. It can use up network resources and slow down or disrupt systems.

A Trojan horse disguises itself as useful or legitimate software. It spreads when a user downloads and runs it, and it may give an attacker unauthorised access to the device.

Ransomware often spreads through malicious email attachments, links, or compromised software. It encrypts the victim's files and demands payment to restore access.

Spyware may be bundled with software or delivered through malicious links. It secretly monitors a user's activity and may steal personal or financial information.

2 .Phishing is a social engineering attack in which an attacker pretends to be a trusted person or organisation to trick someone into revealing sensitive information, clicking a malicious link, or opening an infected attachment.

A typical phishing attack begins when the attacker sends a convincing message, often by email, text, or phone. The message may create urgency or

appear to come from a trusted source. The victim is persuaded to click a link, open an attachment, share login details, or approve a payment. The attacker may then steal information, install malware, or gain access to the victim's account.

Spear phishing targets a specific person or small group and uses details about them to make the message appear genuine. Whaling is a form of targeted phishing aimed at senior executives or other high-profile employees. Vishing uses voice calls or voicemail to trick victims into sharing information or taking an action.

An organisation can reduce phishing risk by providing regular staff awareness training, using email filtering and multi-factor authentication, and establishing a clear process for reporting suspicious messages.

3 .A Denial of Service (DoS) attack attempts to make a website, server, or network unavailable by overwhelming it with traffic or requests from a single source. A Distributed Denial of Service (DDoS) attack has the same goal, but uses many compromised devices, often called a botnet, to send traffic from multiple sources. This makes a DDoS attack harder to block by filtering a single source.

A SYN flood targets the TCP connection process. The attacker sends many SYN requests to a server, often using spoofed source addresses. The server replies with SYN-ACK messages and waits for the final ACK to complete each connection. Because many connections remain incomplete, the server's connection queue fills up, making it difficult for legitimate users to connect.

Two mitigation techniques are:

- SYN cookies: The server avoids reserving resources for a connection until the client completes the TCP handshake.
- Rate limiting or traffic filtering: The network or server limits excessive connection requests and filters suspicious traffic.

4 .A Man-in-the-Middle (MITM) attack occurs when an attacker secretly places themselves between two communicating parties. The attacker can intercept, monitor, or sometimes alter the messages exchanged, while each party believes they are communicating directly with the other.

One technique is ARP poisoning. On a local network, the attacker sends false ARP messages that associate the attacker's device with another device's IP address, such as the network gateway. Traffic may then pass through the attacker's device, where it can be observed or changed.

Another technique is a rogue Wi-Fi access point. The attacker creates a wireless network that looks like a legitimate public hotspot. When a user connects, the attacker can intercept the user's network traffic.

Encryption helps defend against MITM attacks by making intercepted data unreadable to an attacker. For example, HTTPS using valid TLS certificates encrypts data between a user and a website and helps verify the website's identity. Users should check for valid HTTPS connections and avoid ignoring certificate warnings.

5 .Spoofing and sniffing are different network activities. Spoofing means falsifying identifying information in network communications to impersonate another device or user. Sniffing means capturing and examining network packets as they travel across a network.

In IP spoofing, an attacker changes a packet's source IP address to make it appear to come from another device. For example, an attacker may use a forged source address to conceal where attack traffic originated.

In ARP spoofing, an attacker sends false ARP messages on a local network to associate their device's MAC address with another device's IP address, such as the gateway's. As a result, some network traffic may be sent through the attacker's device.

A packet sniffer such as Wireshark can be used legitimately by network administrators to diagnose connection problems, inspect traffic, and investigate security incidents. It can also be misused to capture sensitive information from unencrypted network traffic. Encryption, such as HTTPS, helps protect data because captured packets do not reveal their contents in readable form.

6 . A vulnerability assessment is a systematic process of identifying, evaluating, and prioritising security weaknesses in computer systems, networks, and applications.

The process begins with asset discovery, where the organisation identifies the systems and devices to assess. During scanning, tools examine those assets for known vulnerabilities, outdated software, and insecure configurations. The findings are then analysed and prioritised according to their severity and the risk they pose. The assessor prepares a report describing the vulnerabilities and recommended fixes. The organisation then carries out remediation, such as applying patches or changing configurations, and may scan again to confirm the issues have been addressed.

A vulnerability assessment focuses on finding and ranking weaknesses across systems. Penetration testing goes further by safely attempting to exploit selected weaknesses to show how an attacker could gain access or cause harm.

Commonly used vulnerability scanning tools include Nessus and OpenVAS.

7. CVE stands for *Common Vulnerabilities and Exposures*. It is a system for assigning public identifiers to known cybersecurity vulnerabilities, allowing people to refer to the same vulnerability consistently.

CVSS stands for *Common Vulnerability Scoring System*. It provides a numerical score that describes the severity of a vulnerability. Scores range from 0.0 to 10.0 and are commonly grouped as None (0.0), Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9), and Critical (9.0–10.0).

CVSS scores help organisations compare vulnerabilities and identify those that may need urgent attention. A higher score generally indicates greater potential severity.

However, a high CVSS score alone does not determine patching order. Organisations also consider whether the vulnerability is being actively exploited, whether a fix is available, how exposed the affected system is, and how important that system is to the organisation. A lower-scored vulnerability on a critical, internet-facing system may need attention before a higher-scored issue on a less important, isolated system.

8 .Threat data comes from several sources. Internal sources include an organisation's security logs, incident reports, endpoint alerts, and network monitoring data. External sources include information shared by other organisations, industry groups, and government agencies. Open-source sources provide publicly available information, while commercial sources are paid threat intelligence services that may offer curated reports, threat indicators, and analysis.

Open-Source Intelligence (OSINT) is information gathered and analysed from publicly accessible sources for a specific purpose, such as understanding cyber threats.

Three OSINT sources or tools used in threat intelligence gathering are:

- Shodan: Searches for internet-connected devices and services, helping identify exposed systems.

- VirusTotal: Checks files, URLs, domains, and IP addresses against multiple security tools and databases.
- WHOIS: Provides registration information about domain names and IP address ranges, which can help investigate suspicious infrastructure.

9 .Indicators of Compromise (IoCs) are observable clues that may show a system or network has been compromised. Security teams use them to identify suspicious activity and investigate possible incidents.

IoCs can be grouped into three categories:

- Network-based indicators relate to network activity. Examples include a suspicious IP address and an unusual domain name.
- Host-based indicators are signs found on a device or operating system. Examples include an unexpected user account and an unusual process running on the device.
- File-based indicators relate to files that may be malicious. Examples include a known malicious file hash and an unexpected executable file.

During incident response, security teams compare alerts, logs, and system activity with known IoCs. A match can help them locate affected devices, investigate the scope of an incident, block malicious network connections, quarantine suspicious files, and guide recovery. IoCs are useful clues, but a match should be investigated in context because it may not by itself prove that a system is compromised.

10 . A threat intelligence feed is a regularly updated stream of information about cyber threats. It may include indicators such as malicious IP addresses, domains, file hashes, and details about attacker techniques. Security teams use feeds to help detect and investigate threats.

Threat information is often shared in structured formats such as JSON or CSV. STIX is a standard language for describing and structuring cyber threat information. TAXII is a protocol that allows organisations to exchange STIX information automatically.

Threat feeds have several advantages. They can help security systems identify known malicious activity sooner, and they provide threat information that an organisation may not be able to gather on its own. However, feeds can also contain outdated or inaccurate indicators, which may lead to false alerts. They may also produce too much information for security teams to review, or require extra tools and staff to integrate and manage.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations (2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).